GLA UNIVERSITY MATHURA
Accredited with A+ Grade by NAAC
12-B Status from UGC

Department of Computer Engineering and Applications
Institute of Engineering & Technology

Network Vulnerabilities and Attacks

BCSE-1501
Network Security

Prepared By: MS. Priyanka Sharma
Email : priyankasharma.1@gla.ac.in

Network Vulnerabilities and Attacks

- A **network vulnerability** is a weakness in a communication system that allows attackers to exploit network resources, gain unauthorized access, intercept data, or disrupt services. These vulnerabilities may arise from **misconfigured devices, insecure protocols, weak authentication mechanisms, or poor network architecture**.
- Network attacks can lead to:
- Data theft
- Service disruption
- Unauthorized system access
- Network surveillance
- Financial losses
- Compromise of sensitive information

1. Physical and Data Link Layer Attacks

- These attacks occur at the lowest layers of network communication. They focus on physical network infrastructure and local network communication protocols.
- **Cable Tapping :** In a computer network, devices communicate with each other through physical cables such as Ethernet cables or fiber optic cables. These cables carry data in the form of electronic or light signals. If someone secretly attaches a device to the cable, they can capture and read the data that is travelling through it.
- So, Cable Tapping is the act of secretly connecting to a network cable in order to listen to or capture the data being transmitted between devices.

Types of Cable Tapping

1. Passive Cable Tapping

- The attacker only **listens to the data** without changing anything.
- Example:
  Just secretly recording a phone conversation.
- This is harder to detect.

2. Active Cable Tapping

- The attacker **intercepts and modifies the data** before sending it to the destination.
- Example:
  Someone listening to a phone call and **changing the message before passing it on**.
- This is more dangerous because data can be altered.

MAC Flooding attack

- A network switch keeps a table called the MAC address table (or CAM table) that stores:

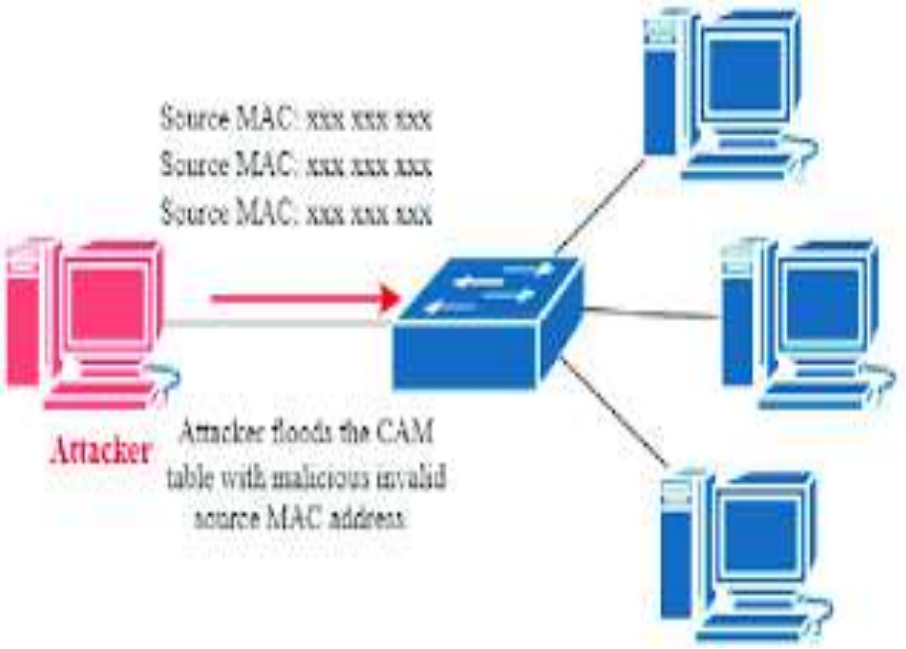
Device MAC address

Corresponding switch port

- This helps the switch send data only to the intended device, not everyone.
- In a **MAC Flooding attack**, the attacker sends thousands of fake MAC addresses to the switch. The switch tries to store all of them in its table. Eventually, the table becomes full.
- When the table is full, the switch cannot remember where devices are, so it starts sending data to all ports, just like an old network hub.
- This allows the attacker to capture network traffic from other devices.

MAC FLOOD ATTACK WORKING

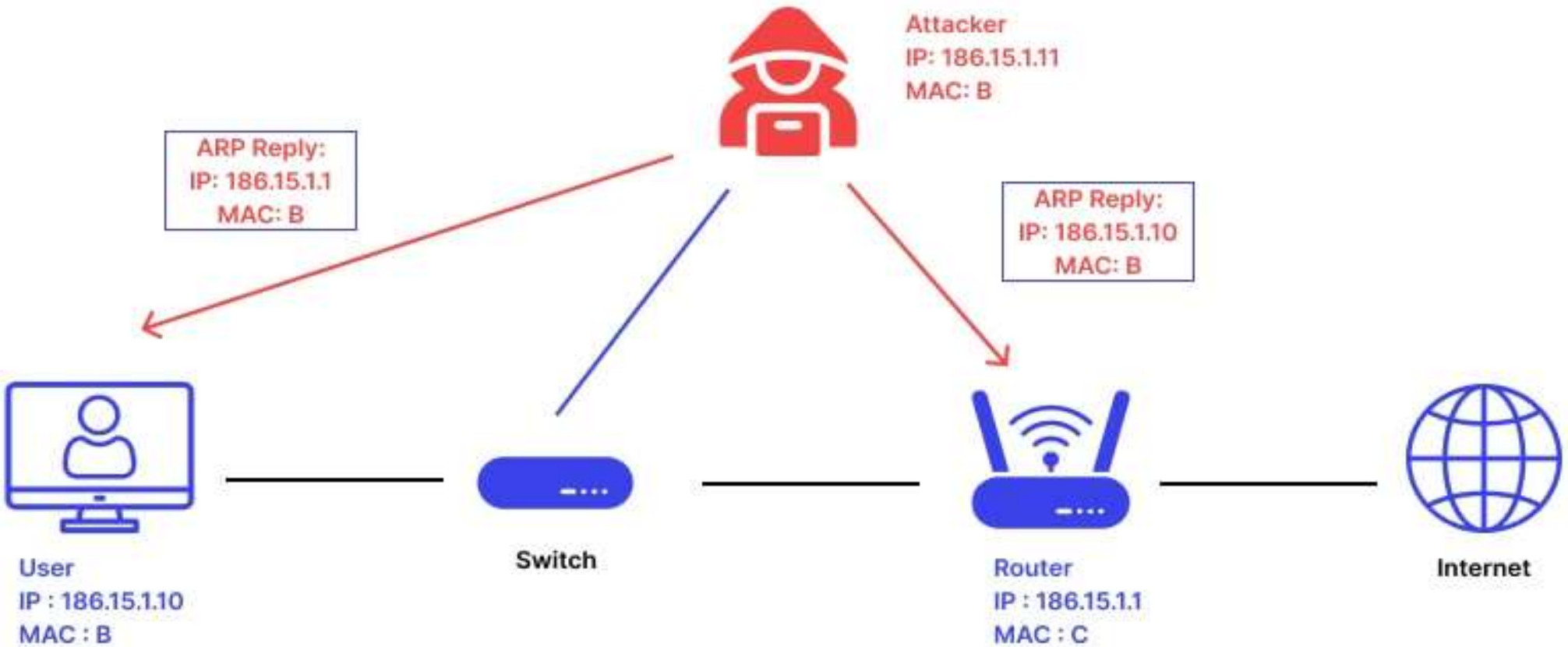
- The attacker connects a computer to the network.
- The attacker sends a huge number of packets with **fake MAC addresses**.
- The switch stores these fake addresses in its **MAC address table**.
- The table reaches its **maximum capacity**.
- The switch cannot store new legitimate addresses.
- The switch starts **broadcasting traffic to all ports**.
- The attacker captures the traffic using a **packet sniffer**



ARP Spoofing

- In a local network, computers need to know which device belongs to which IP address in order to communicate. For this purpose, the network uses a protocol called ARP (Address Resolution Protocol).
- ARP helps convert an IP address into a MAC address so that data can be delivered to the correct device on the network.
- In ARP Spoofing, an attacker sends fake ARP messages in the network so that devices believe the attacker's computer is another trusted device, such as the router or gateway.
- Because of this, network traffic that should go to the router is redirected to the attacker first.
- So the attacker can see, capture, or modify the data before sending it to the real destination.

ARP Spoofing



2. Network and Transport Layer Threats

- Network and Transport layer threats target the communication protocols responsible for transmitting data between devices across networks. These layers mainly include protocols such as IP (Internet Protocol), ICMP (Internet Control Message Protocol), TCP (Transmission Control Protocol), and UDP (User Datagram Protocol).
- Attackers exploit weaknesses in these protocols to disrupt communication, hide their identity, overload servers, or gather information about a network.
- The most common threats in these layers include:
- IP Spoofing
- ICMP Attacks
- SYN Flooding
- UDP Flooding
- Port Scanning

IP Spoofing

- **IP Spoofing** is a technique in which an attacker **forges or modifies the source IP address in a packet** to make it appear as if the packet is coming from a trusted or legitimate system.
- Normally, every data packet contains a **source IP address and a destination IP address**. The destination system uses this information to identify where the packet came from.
- In IP spoofing, attackers change the source address so that the receiving system believes the packet came from a trusted device.

How the Attack Works

- The attacker creates a packet.
- Instead of using their real IP address, they insert a **fake or forged IP address**.
- The target system receives the packet and assumes it came from a trusted source.
- The attacker can bypass security mechanisms or hide their identity.

ICMP Attacks

- **ICMP (Internet Control Message Protocol)** is used for **network diagnostics and error reporting**. It helps devices communicate information about network status.
- For example, the **ping command** uses ICMP to check whether a system is reachable.
- Attackers exploit ICMP messages to flood networks and disrupt services.
- **Common ICMP Attacks**

Ping Flood

- In this attack, the attacker sends a **large number of ICMP echo request packets** to a target system. The target tries to respond to all requests, consuming system resources and network bandwidth.

Smurf Attack

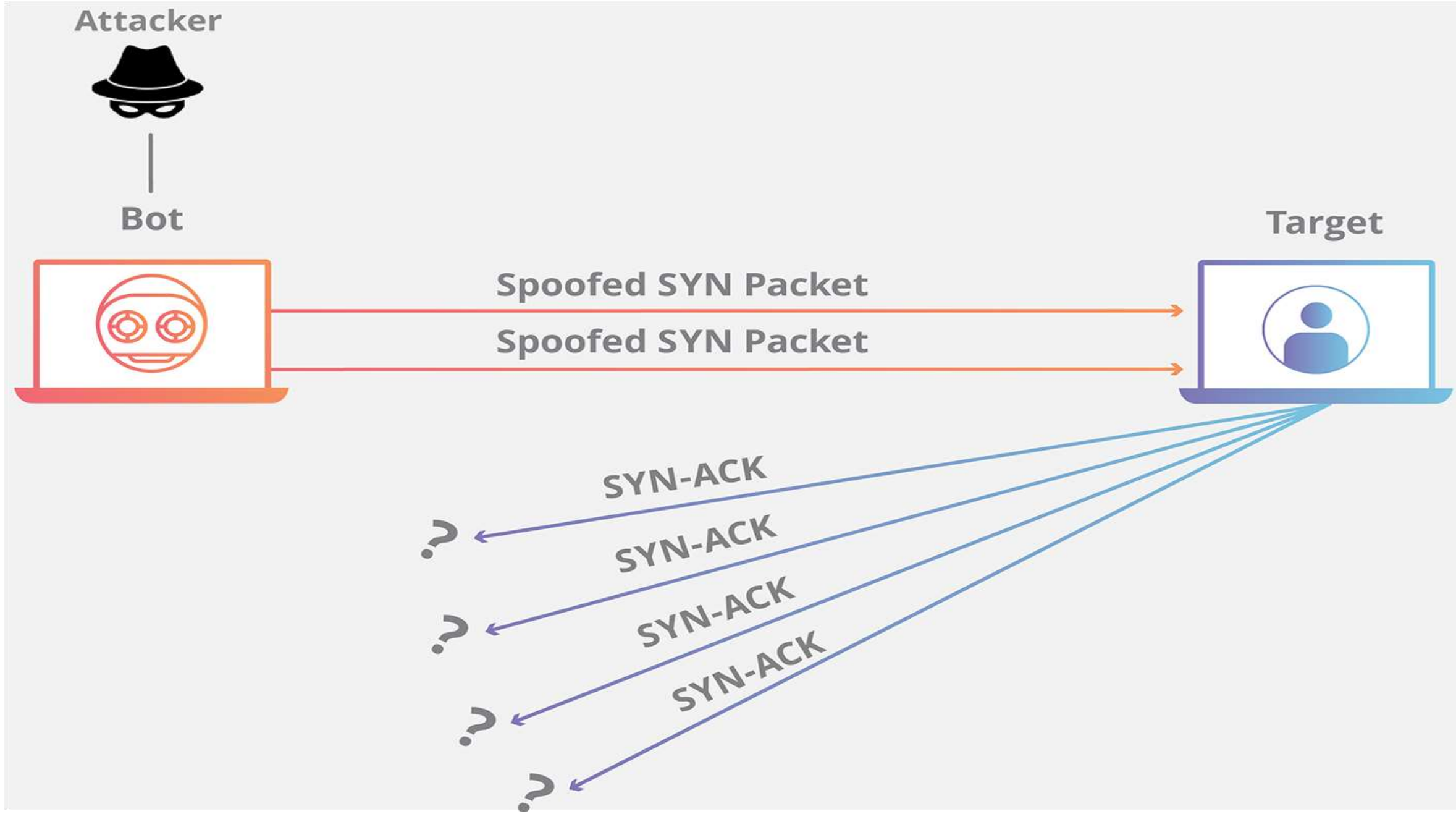
- A Smurf attack is an amplification attack where:
- The attacker sends ICMP requests to a **network broadcast address**.
- The source IP address is spoofed to appear as the victim's address.
- All devices in the network reply to the victim simultaneously.
- This creates massive traffic that overwhelms the victim system

SYN Flood Attack

- A **SYN Flood attack** targets the **TCP connection establishment process**, known as the **three-way handshake**.
- In a SYN flood attack, the attacker sends many **SYN requests but never completes the handshake**.

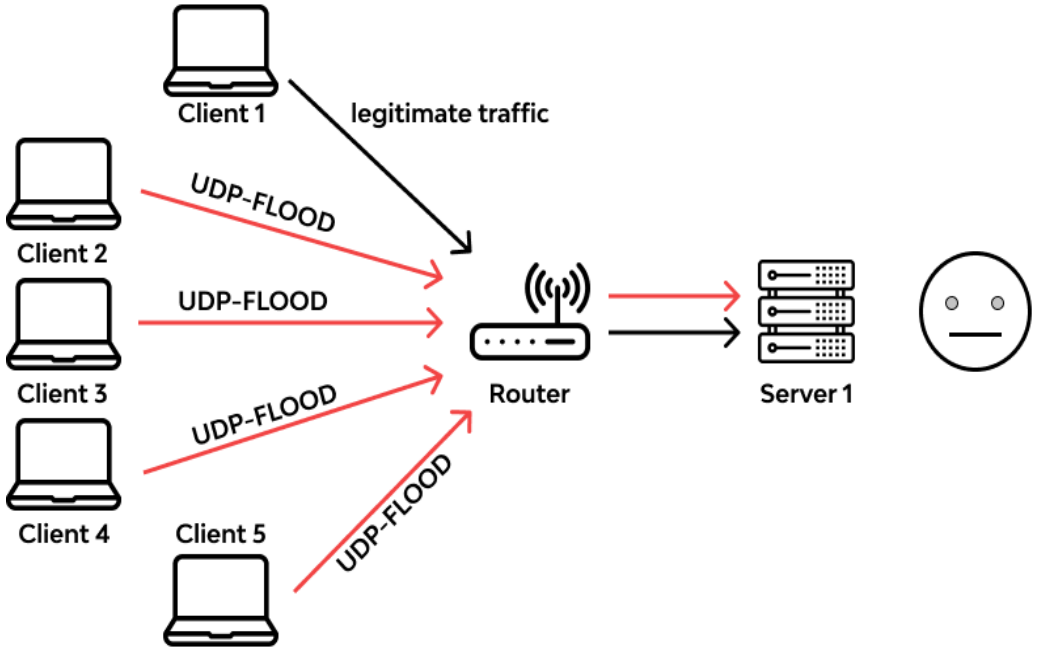
Attack Process

- The attacker sends thousands of SYN packets.
- The server responds with SYN-ACK packets.
- The attacker never sends the final ACK.
- The server waits for confirmation and keeps the connection open.
- Eventually, the server's connection queue becomes full and **legitimate users cannot connect**.
- **Impact**
- Server resource exhaustion
- Network slowdown
- Denial of service for legitimate users


Attacker
Bot
Target
Spoofed SYN Packet
Spoofed SYN Packet
SYN-ACK
SYN-ACK
SYN-ACK
SYN-ACK
?
?
?
?

UDP Flood Attack

- UDP (User Datagram Protocol) is a **connectionless protocol**, meaning it does not establish a connection before sending data.
- Because of this, attackers can easily send large numbers of UDP packets to a target system.
- **Attack Process**
- The attacker sends thousands of UDP packets to random ports.
- The system attempts to process each packet.
- If the port is closed, the system sends an ICMP "Destination Unreachable" message.
- Processing these requests consumes system resources.
- **Impact**
- High CPU usage
- Network congestion
- Service disruption



Port Scanning

- **Port Scanning**
- Technique used to **discover open ports and services** on a system.
- Often the **first stage of network reconnaissance**.

- **How it Works**
  - Attacker sends packets to **multiple ports**.
  - Observes responses to identify **open, closed, or filtered ports**.

- **Common Types**
  - TCP SYN scan
  - TCP connect scan
  - UDP scan

Session & Application Exploits

- The session layer manages **establishing, maintaining, and terminating connections** between systems.
- Session Hijacking :
- **Session Hijacking** is a type of attack where an attacker **takes control of an active user session** to gain unauthorized access to a system or application. It mainly targets the **Session Layer (Layer 5)** of the OSI Model, but is commonly exploited in web applications at the application layer as well.

What is a Session?

- When a user logs into a website:
- The server creates a **session**
- A unique **Session ID (token/cookie)** is assigned
- This session ID is used for authentication in future requests

In session hijacking:

- Attacker **steals or predicts the session ID**
- Uses it to **impersonate the legitimate user**
- Gains access without knowing username/password

Types of Session Hijacking

1. Active Session Hijacking

Attacker takes over an ongoing session
•Legitimate user may get disconnected
Example:

- You log into your email account
- Attacker steals your session cookie
- Attacker logs in using that cookie
- You suddenly get logged out

2. Passive Session Hijacking

- Attacker **only observes traffic**
- Does not interrupt session

Example:

- You use public Wi-Fi in a café
- Attacker runs a packet sniffer
- Captures your session ID and login data

3. **TCP Session Hijacking**

Explanation:

- Attacker predicts **TCP sequence numbers**
- Injects fake packets into communication

Example:

- User is communicating with a server
- Attacker sends forged packets pretending to be user
- Server accepts attacker's commands
- **Man-in-the-Middle (MITM) Hijacking**

Explanation:

- Attacker sits between user and server
- Intercepts/modifies communication

Example:

- You connect to fake Wi-Fi hotspot
- Attacker monitors all traffic
- Captures your session ID

Man-in-the-Middle (MITM) Attack

- A **Man-in-the-Middle (MITM) attack** is a cyberattack where an attacker secretly **intercepts and possibly alters communication** between two parties who believe they are directly communicating with each other.

How MITM Attack Works

- User connects to a network (e.g., public Wi-Fi)
- Attacker positions themselves in the network
- Intercepts communication between user and server
- Can:
  - Read sensitive data
  - Modify messages
  - Inject malicious content

SQL Injection

- **SQL Injection (SQLi)** is a type of **application-layer cyber attack** in which an attacker inserts or “injects” malicious SQL queries into input fields or parameters of a web application, in order to **manipulate the backend database**, gain **unauthorized access**, or **retrieve/modify sensitive data**.
- SQL Injection is an attack where malicious SQL statements are inserted into input fields to exploit vulnerabilities in an application and access or manipulate database data.
- **SQL Injection countermeasures:**

Input Validation: Accept only valid and expected user input.

Prepared Statements: Use parameterized queries to separate data from SQL commands.

Stored Procedures: Execute predefined queries to reduce direct manipulation.

Escaping Characters: Convert special characters into safe format.

Least Privilege: Give minimum database access rights.

Hide Error Messages: Do not expose database errors to users.

Web Application Firewall (WAF): Filter and block malicious SQL requests.

DoS / DDoS Attacks

- DoS (Denial of Service) is an attack where a single attacker tries to make a website or server unavailable by overloading it with too many requests.
- **impacts of DoS/DDoS**
- Website downtime
- Loss of customers
- Financial loss
- Reputation damage

DDoS prevention techniques :

- **Firewalls:** Filter and block malicious traffic.
- **Rate Limiting:** Restrict number of requests from a single user/IP.
- **Load Balancing:** Distribute traffic across multiple servers.
- **DDoS Protection Services:** Use cloud/CDN-based protection systems.
- **Traffic Monitoring:** Detect unusual spikes in network traffic.
- **IP Blocking / Blacklisting:** Block suspicious or malicious IP addresses.

Botnet

- A **Botnet** is a network of **infected computers (called bots or zombies)** that are controlled by an attacker without the owners knowing.
- Controlled through a **Command and Control (C&C) server**

How Botnet Works

- Attacker spreads malware
- Systems get infected
- All infected systems connect to attacker (C&C server)
- Attacker sends commands
- Bots perform attacks together

Prevention of Botnets

- Install antivirus and anti-malware
- Avoid downloading unknown files
- Keep systems updated
- Use strong passwords
- Monitor network traffic

DNS Spoofing

- **DNS Spoofing (DNS Cache Poisoning)** is an attack where an attacker **provides fake DNS information** to redirect users to a malicious website instead of the real one.

How DNS Spoofing Works

- User requests a website
- Attacker injects fake DNS response
- DNS cache stores wrong IP
- User is redirected to malicious site
- **Types of DNS Spoofing**

1. DNS Cache Poisoning

- Fake data stored in DNS cache

2. Man-in-the-Middle DNS Attack

- Attacker intercepts DNS requests

3. Rogue DNS Server

- Attacker sets up fake DNS server

Network Access Control (NAC)

- **Network Access Control (NAC)** is a security framework that ensures **only authorized users and compliant devices** are allowed to access a network.
- It acts as a **gatekeeper** that enforces security policies before granting access.

Components of Network Access Control :

- **Authentication:** Verifies the identity of the user or device.
- **Authorization:** Determines the level of access granted after authentication.
- **Posture Assessment:** Checks the security status of the device (e.g., antivirus, updates).
- **Policy Enforcement:** Applies rules to allow, block, or restrict access.
- **Monitoring:** Continuously observes network activity after access is granted.

Proxy Server

- A **Proxy Server** is an intermediary system that **acts as a bridge between a user (client) and the internet**, forwarding requests and responses.
- **Countermeasures:**

•Use firewalls (e.g., iptables) to filter and block unauthorized traffic.
•Deploy IDS/IPS to detect and prevent malicious activities.
•Use IPsec/VPN to encrypt data and prevent interception.
•Apply anti-spoofing techniques to block fake IP addresses.
•Implement network segmentation (VLAN/DMZ) to limit attack spread.
•Use rate limiting to prevent DoS/DDoS attacks.
•Enable secure routing protocols to avoid routing attacks.
•Perform regular patching to fix vulnerabilities.
•Monitor logs continuously to detect suspicious behavior.